Securing VMWare ESXi Part 3: Host State Controls

trimarcsecurity.com/hub-post/securing-vmware-esxi-part-3

Demetrios Mustakas January 14, 2022

Updated: Dec 13, 2024

Introduction

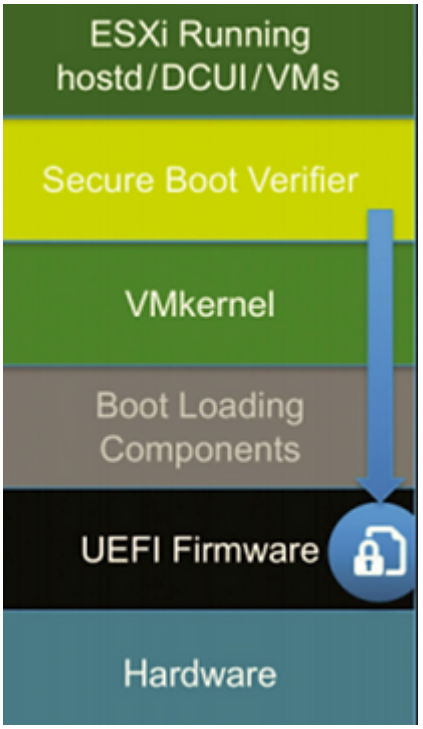
This is the third part of a multi-article series exploring ESXi hypervisor architecture and its many security features. This article focuses on the host state controls. These controls are key to configuration as well as attesting to the known secure state of a host.

Host State Controls

Host State Controls takes into consideration aspects of the ESXi host such as if Secure Boot is implemented, what Boot Mode is being used, how host configuration is maintained, and whether or not Quick Boot is enabled. This concerns the configuration and change control states of the ESXi host server as well as how it acts during operation in the vSphere environment.

Secure Boot

Secure boot is part of the UEFI firmware standard. With secure boot enabled, a machine refuses to load any UEFI driver or application unless the operating system bootloader is cryptographically signed. Starting with vSphere 6.5, ESXi supports secure boot if it is enabled in the hardware.



If the hardware platform supports UEFI and all vSphere Installation Bundles (VIB) are signed at no less than Partner Support level, Trimarc recommends that all production ESXi Hosts be configured with Secure Boot. If your organization meets the requirements, consider enabling Secure Boot on all ESXi hosts. Attestation status can then be monitored to ensure that all hosts boot in a known state. Ensure that the TPM is configured in the ESXi host's BIOS to use the SHA-256 hashing algorithm and the TIS/FIFO (First-In, First-Out) interface and not CRB (Command Response Buffer).

Lockdown Mode

Using the ESXi lockdown mode and limiting access to the ESXi Shell can further contribute to a more secure environment. In lockdown mode, direct access to a host is restricted while access through vCenter server is available. Starting with vSphere 6.0, there are distinct configurations which offer different degrees of lockdown: normal lockdown mode or strict lockdown mode.

While Lockdown mode prevents users from logging in to hosts directly, exceptions can be specified. Exception User list (available in vSphere 6.0) identifies specific users that do not lose their privileges when the host enters lockdown mode. This is useful when planning for third-party solutions and applications require access to the host directly while a host is in lockdown mode.

Here's an article that describes the different lockdown “modes” in addition to helpful notes and scripts to modify the setting: https://www.yelof.com/2015/03/13/vsphere-6-0-lockdown-modes/

Host Profiles

Host profiles allow standardization for ESXi hosts and automate compliance to these configuration settings. This works by encapsulating a reference host configuration and turning it into a profile, which can then be used or applied to other hosts or clusters of hosts.

Host profiles offer control over many aspects of host configuration including memory, storage, networking. Host profiles are configured for each specified reference host from the vSphere Web Client and apply the host profile to all hosts that share the characteristics of the reference host. Host profiles can also be used to help monitor hosts for configuration changes. Host profiles can be attached to a cluster to apply it to all hosts in the cluster.

Configuration control is a major challenge to security. Host profiles can be used to guard against configuration drift, the tendency over time of systems to change configuration for one reason or another, deviating from a known baseline. Host profiles created on established vSphere hosts can be used as the basis for provisioning new hosts. These are crucial in cases where strict compliancy (i.e., PCI, HIPPA, etc.) is required for the authority to operate.

Conclusion

Configuration controls over ESXi hosts can help not only enforce security policies but also recognize when hosts deviate from a known secure state. Configuration management of hosts is the next step in securing a vSphere environment.

References and Additional Information

- Securing VMWare ESXi Series
- VMware KB article explains the supportability of platforms for Secure Boot
- Regarding vSphere 6.5 Secure Boot for consideration
- VMware provides instructions on how to configure Secure Boot
- Guidance on how to remove unwanted VIBs from an ESXi host
- Article that describes the different lockdown “modes” in addition to helpful notes and scripts to modify the setting
- Helpful articles on Host Profile understanding and granular compliance results walk-thru

Trimarc provides leading expertise in security solutions including security reviews, strategy, architecture, and implementation. Our methodology leverages our internal research and custom tooling which better discovers multiple security issues attackers could exploit to

compromise the environment. Trimarc security services fit between traditional compliance/audit reviews and standard penetration testing/red teaming engagements, providing deep understanding of Microsoft and Virtualization technologies, typical security issues and misconfigurations, and provide recommendations based on our own best practices custom-tailored to balance operational and security challenges.

Trimarc performs security assessments that cover Active Directory, Azure AD & Microsoft Office 365, and VMWare. If you would like to improve the security of your VMWare infrastructure, let us know and we can discuss the Trimarc Virtual Infrastructure Security Assessment (VISA).

How to contact Trimarc

Version	Release Name	Release Date	Build Number
ESXi 7.0 Update 2a	ESXi 7.0 Update 2a	2021/04/29	17867351
ESXi 7.0 Update 2	ESXi 7.0 Update 2	2021/03/09	17630552
ESXi 7.0 Update 1d	ESXi 7.0 Update 1d	2021/02/02	17551050
ESXi 7.0 Update 1c	ESXi 7.0 Update 1c	2020/12/17	17325551
ESXi 7.0 Update 1c (security Only)	ESXi 7.0 Update 1c (security Only)	2020/12/17	17325020
ESXi 7.0 Update 1b	ESXi 7.0 Update 1b	2020/11/19	17168206
ESXi 7.0 Update 1a	ESXi 7.0 Update 1a	2020/11/04	17119627
ESXi 7.0 Update 1	ESXi 7.0 Update 1	2020/10/06	16850804
ESXi 7.0b	ESXi 7.0b	2020/06/23	16324942
ESXi 7.0 GA	ESXi 7.0 GA	2020/04/02	15843807